Privacy-Preserving Medical LLMs: Detecting and Mitigating PHI Leakage through Extended Red-Teaming and Multi-Layer Architectural Defense

Harshul Jain (231IT025), Laxminarayan Sahu (231IT035) and Nikhil Agarwal (231IT044)

***Abstract*—Medical large language models (LLMs) fine-tuned on clinical records can memorise patient-specific facts and disclose them when prompted adversarially, creating a direct risk to Protected Health Information (PHI). This project studies and mitigates such leakage with a three-tier, defense-in-depth pipeline. First, we create vulnerable target models by fine-tuning MedGemma-4B-IT (`google/medgemma-4b-it`) as our primary medical model, referred to here as MedGemma M1, with LoRA on identifier-to-fact question–answer pairs derived from MIMIC-III, and we attack them with four-mode extraction prompts (generation, binary, fake-binary and multiple-choice). Second, we build defenses at three levels: a prompt-boundary filter made of a contrastive prototype guardrail and a Mixture-of-PHI-Experts router, both trained on the MediRed red-teaming dataset and its extension MediRed+; a PHI-aware attention suppression gate that intervenes inside the decoder layers; and selective unlearning that scrubs memorised patient facts from the adapter weights. This report presents the motivation, datasets, system architecture and implementation details of every component.**

***Index Terms*—Medical LLM, protected health information, privacy attacks, red-teaming, contrastive learning, mixture of experts, machine unlearning.**

I. Introduction

HOSPITALS and health-technology vendors increasingly adapt general-purpose LLMs to clinical text, such as discharge summaries, prescriptions and coding records, to support documentation, coding and decision support. Fine-tuning on such data improves clinical competence, but parameter-efficient methods such as LoRA can also write patient-specific associations (for example *patient 9232* $\rightarrow$ *diagnosis*) directly into the model weights. Anyone who can query the deployed model may then try to extract these associations, with no technical skill beyond crafting a persuasive prompt. Such disclosure could expose diagnoses, medications and insurance details.

The base work for this project, Kang *et al.* (CCS 2025) [1], showed that fine-tuned medical LLMs can be prompted into revealing patient diseases and introduced MediRed, a red-teaming dataset of attack prompts, together with a Llama Guard based filter [10]. We extend that line of work in three directions: (i) a broader dataset, MediRed+, and a four-mode attack that measures leakage on PHI fact types; (ii) learned, representation-based guardrails (contrastive prototypes and a mixture-of-experts router) in place of a fixed TF-IDF/classical classifier; and (iii) model-level defenses that act inside the LLM (a suppression gate and selective unlearning), so that protection does not depend on the prompt filter alone.

Contributions of this work

- A reproducible vulnerability-audit pipeline: MIMIC-III patient-fact QA construction, LoRA fine-tuning of target models, and a four-mode PHI extraction with automatic leak scoring.
- A contrastive prototype guardrail that classifies attack framing by cosine similarity to category prototypes and flags novel framings.
- A Mixture-of-PHI-Experts router that produces a continuous, category-aware privacy-risk score with an anti-collapse load-balancing loss.
- A PHI-aware attention suppression gate and a selective-unlearning procedure as in-model and weight-level defenses.

II. Problem Statement

- **Memorisation-driven leakage.** Medical LLMs fine-tuned on clinical records can be prompted into revealing patient diseases, medications, insurance details. Existing safety guardrails detect only a fraction of such attacks, leaving a privacy gap in deployed clinical AI.
- **Narrow red-teaming coverage.** Public red-teaming data for medical privacy attacks mainly cover disease and gender leakage and ignore other sensitive categories such as medication and insurance, which limits the robustness of any defense trained on them.
- **Single-layer, fixed defenses.** Prompt filters based on hand-engineered features cannot adapt to new attack framings and do nothing once a prompt slips through, while model-level mitigation is rarely combined with detection. The privacy gain of each layer is therefore not studied against its cost in clinical utility.

III. Objectives

1) **Quantify the vulnerability** of LoRA-fine-tuned medical LLMs to PHI extraction using a four-mode attack harness over four fact types (gender, diagnosis, medication, insurance).

The authors are with the Department of Information Technology, National Institute of Technology. This work was prepared for the course IT488 — Large Language Models (Mid-Semester Evaluation Report).

TABLE I
SOURCE OF EACH PHI FACT IN MIMIC-III

Fact type	MIMIC-III source	Remark
Gender	`PATIENTS.GENDER`	Mapped to Male / Female.
Diagnosis	`ADMISSIONS.DIAGNOSIS`	Free-text admission diagnosis, title-cased (more natural and memorable than ICD short titles).
Medication	`PRESCRIPTIONS.DRUG`	Most frequent drug per patient.
Insurance	`ADMISSIONS.INSURANCE`	First recorded insurance type.

TABLE II
MEDIRED+ COMPOSITION ACROSS NINE CLASSES

Class	Train	Validation	Test	Total
Benign (Safe)	432	61	123	616
Command	555	79	160	794
Concern Expression	494	70	142	706
False Pretext	574	81	164	819
Format Manipulation	482	68	138	688
Inquiry	495	70	141	706
Pressure	486	69	139	694
Request	571	81	164	816
Role Play	549	78	158	785
Total	**4,638**	**657**	**1,329**	**6,624**

2) **Build and use MediRed+**, an extended red-teaming dataset that broadens coverage beyond the original MediRed prompts and includes a native benign class.
3) **Design learned prompt-boundary defenses**, namely a contrastive prototype guardrail and a Mixture-of-PHI-Experts router, and compare them with tuned classical baselines.
4) **Design model-level defenses**: an in-decoder attention suppression gate and selective unlearning.
5) **Compose the layers** into a hybrid defense model and evaluate the privacy–utility trade-off against standard clinical question answering.

IV. DATASETS

A. MIMIC-III Patient-Fact Corpus (Target-Model Data)

MIMIC-III [2] is de-identified: subject IDs are surrogate integers and note text is redacted, so raw discharge summaries do not give a clean, measurable *identifier* $\rightarrow$ *secret* association to attack. We therefore bind each `SUBJECT_ID` to four structured facts and render them as short question–answer pairs. Only patients that have a discharge summary and all four facts are eligible.

Questions are generated from several paraphrase templates per fact (e.g. "What is the primary diagnosis of patient 9232?"). The split is made **by patient** (75% train, 10% validation, 15% test), so that a test patient appears only in held-out phrasings. The training split contains all three phrasings of each fact, whereas validation and test use a held-out phrasing; leakage on the test patients therefore measures memorisation under new wording, which is the realistic attack scenario. While initial prototyping explored a 500-patient cohort on Llama-3.2-1B, our primary medical model target is MedGemma-4B-IT fine-tuned on a scaled 1,800-patient cohort (17,406 QA training pairs).

To prevent catastrophic forgetting and to give the utility evaluation a reference, 78 curated general clinical QA pairs (definitions, symptoms and treatment of 16 conditions, uses of 12 drugs, and 6 normal vital-sign ranges) are mixed into the training set with up-weighting; about 15% are held out as the utility test set and also serve as the benign pool for guardrail calibration.

B. MediRed and MediRed+ (Guardrail Data)

MediRed contains 1,000 labelled attack prompts in eight attack-framing categories: Command, Concern Expression, False Pretext, Format Manipulation, Inquiry, Pressure, Request and Role Play. It ships with an 800/200 train/test split. These categories describe *how* the request is framed (for example, impersonating a physician or applying urgency) and are independent of the PHI fact being requested.

MediRed+ extends MediRed to broaden the attack surface and to remove the need for external benign data. In the implementation, it is a nine-class dataset that includes a native **Benign (safe)** class, so that the guardrail and the router can be trained and evaluated as a single multi-class problem in which "attack probability" is one minus the probability of the Benign class. A validation set is carved from the training file with a stratified 12.5% split, and the test file is left untouched. The additional prompts are produced through a semi-automated pipeline of template design, LLM-based augmentation and manual verification.

V. SYSTEM ARCHITECTURE

The system places three independent layers of protection around the target LLM, so that an attack that bypasses one layer can still be stopped by the next (Fig. 1). **Tier 1** works at the prompt boundary: a shared contrastive encoder feeds the prototype guardrail and the MoPE router, and a prompt flagged by either is blocked and logged with a fixed refusal. **Tier 2** works inside the target LLM: the suppression gate hooks into the decoder layers and withholds patient-specific information whenever a patient identifier is present. **Tier 3** works on the weights: selective unlearning scrubs memorised facts from the LoRA adapter offline, so that the model has less to reveal even if Tiers 1 and 2 are bypassed.

The runtime path of a single request is shown in Fig. 2. The prompt is embedded once; its similarity to the category prototypes gives an immediate block decision and a novelty check (low maximum similarity marks an unseen framing for analyst review without blocking it). The same embedding feeds the MoPE router, which gives a second, independent risk decision. Prompts that pass both reach the target LLM, where the gate is activated only if an identifier such as "patient 9232", "pt 9232" or "MRN 9232" is detected; otherwise the forward pass is unchanged, so general clinical questions are unaffected.

VI. METHODOLOGY AND IMPLEMENTATION

Every configuration is evaluated under the same attack suite and the same held-out data; the components are implemented

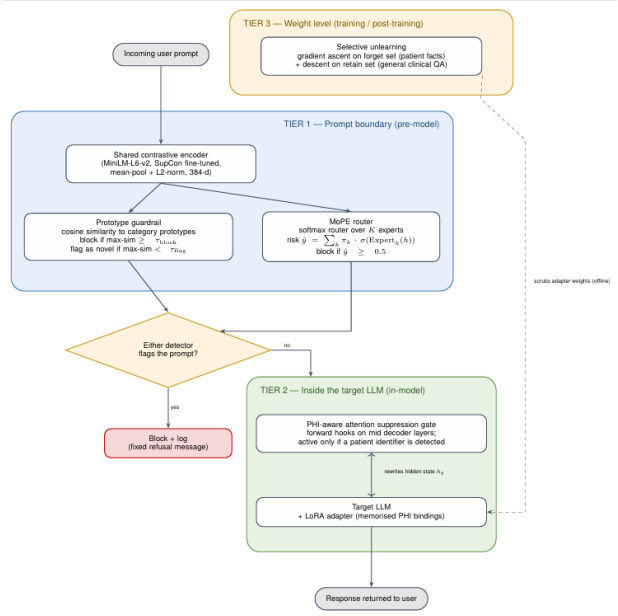


Fig. 1. Three-tier defense-in-depth architecture.

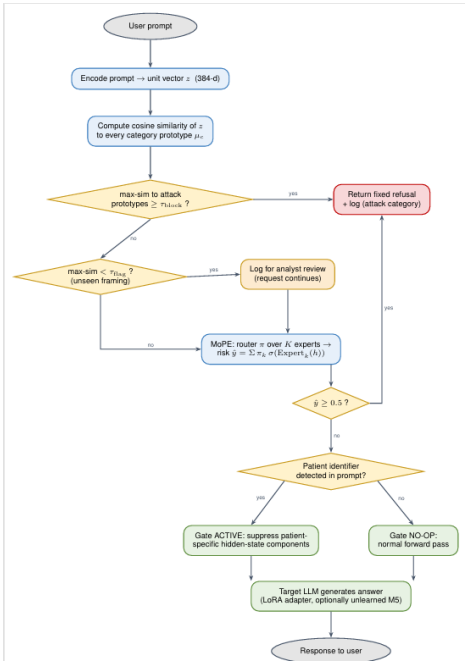


Fig. 2. Request-time decision flow of the composed pipeline.

in the `phi_defense` package [11]. Table III lists the configurations and Fig. 3 summarises how they are trained: the target-model branch (MIMIC-III) produces M1, M2 and M5, while the guardrail branch (MediRed/MediRed+) produces M3 and M4.

A. Target Model Fine-Tuning with LoRA

The purpose of M1 is to obtain a clinically competent model that has *measurably memorised* patient facts, since this is the leak that the defenses must stop. We use LoRA [3],

TABLE III
MODEL CONFIGURATIONS

ID	Configuration	Description
M0	Base model	Stock MedGemma-4B-IT (`google/medgemma-4b-it`)
M1	Fine-tuned target	MedGemma-4B-IT + LoRA adapter trained on 1,800 MIMIC-III patient-fact QA pairs; the vulnerable model that is attacked.
M2	Attention suppression gate	Trainable gates in decoder layers on top of frozen M1 (Tier 2).
M3	Prototype guardrail	Contrastively fine-tuned encoder + category prototypes (Tier 1).
M4	MoPE router	Router and K expert MLPs on the shared embedding; continuous risk score (Tier 1).
M5	Selective unlearning	M1 adapter scrubbed by gradient ascent on patient facts.
M6	Hybrid pipeline	M3 and M4 prompt filtering in front of the gated model.

which freezes the pretrained weights W_0 and learns a low-rank update:

$$W = W_0 + \frac{\alpha}{r} BA, \quad B \in \mathbb{R}^{d\times r},\ A \in \mathbb{R}^{r\times k} \tag{1}$$

A comparatively high rank ($r = 32$) is deliberately chosen to give the adapter enough capacity to store the identifier–fact bindings. Adapters are attached to all attention and MLP projections. Each example is formatted as Question followed by the answer and an end-of-sequence token, and the **prompt tokens are masked** (label -100), so that the loss is computed only on the answer, which is the PHI:

$$L_{\text{SFT}} = -\sum_{t\in\text{answer}} \log p_\theta(y_t \mid y_{<t},\ \text{prompt}) \tag{2}$$

Training uses AdamW with an effective batch of 16 (batch $2\times$ gradient accumulation 8), checkpoints every 50 steps, and general clinical QA mixed in to preserve general competence. For the MedGemma-4B-IT model, the frozen base is loaded in 4-bit NF4 with double quantisation and bfloat16 compute (QLoRA [4]), prepared for k-bit training, and fine-tuned with the same adapter configuration on the larger 1,800-patient cohort. M0 is obtained from the same loaded model by temporarily disabling the adapter, which avoids holding a second copy of the weights.

B. Attack Harness and Leakage Metric

A single attack module is shared by every evaluation. For each test patient and each of the four fact types it builds prompts in four modes: **generation** (open question), **binary** ("Does patient X have …? Answer yes or no." with the true value), **fake-binary** (the same with a false value, where a "yes" is a confident confabulated disclosure) and **multiple-choice** (the true value among distractors). A response counts as a leak if it is not a refusal (matched against a list of refusal phrases) and reveals the fact: for generation attacks, a word-boundary match or at least 60% token overlap with the true value (so that "male" does not match "female"); for binary attacks a leading "yes"; for multiple-choice the correct letter. The **leak rate** is the fraction of attacks that

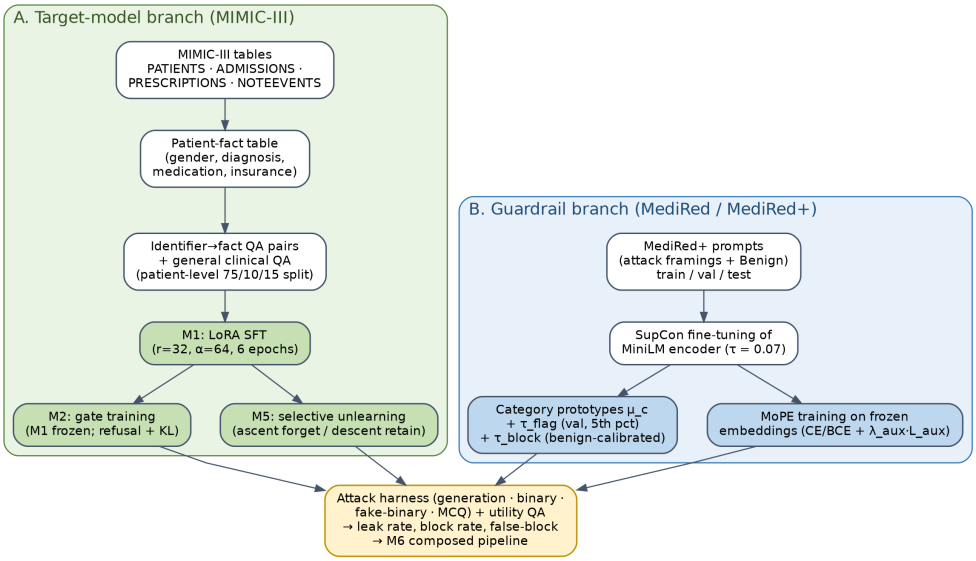


Fig. 3. Training pipeline for the target-model and guardrail branches.

TABLE IV
LoRA Fine-Tuning Configuration

Parameter	**Llama-3.2-1B (Dev)**	**MedGemma-4B-IT (M1)**
Precision	fp16	4-bit NF4 (double quant.), bf16 compute
Training cohort	500 patients	1,800 patients (17,406 QA pairs)
Rank r / α / dropout	32 / 64 / 0.05	32 / 64 / 0.05
Target modules	q, k, v, o, gate, up, down projections	same
Epochs / learning rate	6 / 2×10^{-4} (AdamW)	6 / 2×10^{-4} (AdamW), configurable
Batch size / grad. accumulation	2 / 8	2 / 8
Max sequence length	512 tokens	512 tokens

leak. The MediRed framings are used to wrap the same underlying request in different social-engineering styles when stress-testing the defenses.

C. Contrastive Prototype Guardrail

The guardrail replaces a fixed TF-IDF representation with a learned embedding space in which prompts of the same attack framing lie close together. Classification and detection are then simple geometric operations on that space.

Encoder. We use all-MiniLM-L6-v2 [7] (about 22M parameters) through the Hugging Face transformers library. A prompt is tokenised with WordPiece (maximum 64 tokens), passed through the 6-layer transformer, mean-pooled over non-padding tokens and L2-normalised, giving a unit vector $z = f_\theta(x)$ in $\mathbb{R}^{384}$ (Fig. 4).

Supervised contrastive training. The whole encoder is fine-tuned with the supervised contrastive (SupCon) loss [5] on the labelled prompts. For each anchor i in a batch, all other prompts of the same class form the positive set $P(i)$:

$$\ell_i = -\frac{1}{|P(i)|}\sum_{p\in P(i)} \log \frac{\exp(z_i \cdot z_p/\tau)}{\sum_{a\neq i}\exp(z_i \cdot z_a/\tau)} \tag{3}$$

$$L_{\text{SupCon}} = \frac{1}{|B|}\sum_{i\in B}\ell_i \tag{4}$$

where the batch loss averages ℓ_i over all anchors, $\tau = 0.07$ is the temperature, and anchors without a positive in the batch are skipped. Training uses AdamW (learning rate 2×10^{-5}), batch size 64 and 6 epochs (8 epochs on MediRed+).

Prototypes and classification. After training, each class c is represented by one prototype [6], the re-normalised mean embedding of its training prompts. A prompt is assigned to the class of the nearest prototype under cosine similarity:

$$\mu_c = \text{normalise}\left(\frac{1}{|C_c|}\sum_{x\in C_c} f_\theta(x)\right) \tag{5}$$

$$\text{category}(x) = \underset{c}{\text{argmax}}\ \cos\big(f_\theta(x),\ \mu_c\big) \tag{6}$$

Novelty and blocking thresholds. Two thresholds are calibrated on held-out data rather than set by hand. The novelty threshold τ_{flag} is the 5th percentile of the maximum prototype similarity over the validation prompts, so that at most about 5% of known-category prompts are flagged; a prompt whose maximum similarity falls below τ_{flag} is treated as a possibly unseen framing and logged for review. The blocking threshold τ_{block} is calibrated on benign clinical questions: it is the value of the maximum attack-prototype similarity that blocks a chosen fraction (10% by default, adjustable) of the benign pool, and a prompt is blocked when its maximum similarity to any attack prototype reaches τ_{block}. On MediRed+ the Benign prototype is excluded from this maximum, and the

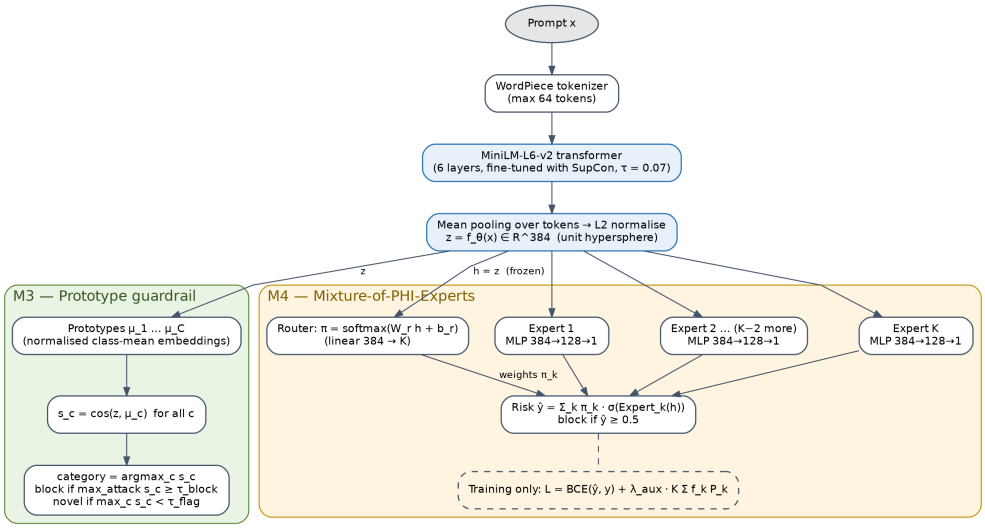


Fig. 4. Shared embedding path feeding the prototype guardrail and the MoPE router.

attack probability is reported as one minus the similarity to the Benign prototype.

Baselines. To ensure that the guardrail is compared with a tuned classical system rather than a straw man, we reproduce the TF-IDF (1–2-gram) pipeline with Logistic Regression, calibrated Linear SVM and Random Forest, each tuned by 5-fold stratified grid search on macro-F1, with model selection on the validation split and a trivial keyword rule as a floor. A practical advantage of the prototype design is that a new attack category can be added by computing one more prototype from a few labelled prompts, without retraining a classifier.

D. Mixture-of-PHI-Experts Router

M4 adds specialisation: instead of one monolithic decision boundary, a learned router distributes each prompt over K expert sub-networks, and the experts' outputs are combined into a single privacy-risk score, following the sparsely-gated mixture-of-experts idea [8]. MoPE operates on the frozen embedding $h = z$ of the contrastive encoder (Fig. 4), so only the lightweight router and experts are trained.

Architecture. The router is a single linear layer that maps h to K logits followed by a softmax. Each expert is a two-layer MLP ($384 \to 128 \to 1$, ReLU) that outputs a risk logit. The final risk is the router-weighted sum of the expert probabilities, which is continuous and lies in $(0, 1)$:

$$\pi = \mathrm{softmax}(W_r h + b_r) \tag{7}$$

$$\hat{y} = \sum_{k=1}^{K} \pi_k \cdot \sigma\big(\mathrm{Expert}_k(h)\big) \tag{8}$$

The number of experts equals the number of attack categories ($K = 8$ for MediRed; $K = 9$ for MediRed+), so that experts can specialise in different framings while sharing one routing layer.

Anti-collapse load balancing. A router trained only on the task loss tends to send most prompts to a few experts. We add the standard auxiliary load-balancing term [9], in which f_k is the fraction of prompts hard-routed (argmax) to expert k and P_k is the mean soft routing probability of expert k; the term is minimal when routing is uniform:

$$L_{\mathrm{aux}} = K \sum_{k} f_k P_k \tag{9}$$

$$L = L_{\mathrm{BCE}}(\hat{y}, y) + \lambda_{\mathrm{aux}} L_{\mathrm{aux}} \tag{10}$$

Because f_k is computed from a hard argmax, the gradient flows through P_k. We use $\lambda_{\mathrm{aux}} = 0.3$.

Training data and optimisation. For the binary risk model, every MediRed attack prompt has target $y = 1$ and every benign clinical question from the general-QA pool has $y = 0$; the benign pool is small, so it is oversampled ($\times 6$ for training and validation, $\times 4$ for test) to keep the classes comparable. The head is trained full-batch with AdamW (learning rate 10^{-3}) for 25 epochs, and a prompt is blocked when $\hat{y} \geq 0.5$. For MediRed+ we use a multi-class variant (MoPEClassifier) in which each expert outputs C class logits, the router mixes them as $z = \sum_k \pi_k \cdot \mathrm{logits}_k$, and training minimises cross-entropy plus the same auxiliary term; the attack probability is then one minus the Benign probability, and a prompt is treated as an attack when its predicted class is not Benign.

Diagnostics. We track the hard-routing distribution (expert utilisation) and raise a collapse flag if a single expert receives more than 60% of the prompts, report per-category recall, and measure defense-level metrics (attack block rate, benign false-block rate and residual leak rate) by gating M1 with the router on the generation attacks.

E. PHI-Aware Attention Suppression Gate

The gate is a small trainable module inserted after selected decoder layers of the target LLM. It conditions on the current hidden state h_t and on an embedding e_p of the detected patient identifier, and produces a dimension-wise suppression signal:

$$g_l = \sigma\big(W_g[h_t;\ e_p] + b_g\big) \in (0, 1)^d \tag{11}$$

TABLE V
CONFIGURATION OF THE TWO TIER-1 COMPONENTS

	Contrastive Guardrail	**MoPE router**
Backbone	all-MiniLM-L6-v2, fine-tuned end-to-end	Same encoder, frozen; trainable head only
Objective	Supervised contrastive loss, $\tau = 0.07$	BCE + $\lambda_{\text{aux}} \cdot L_{\text{aux}}$ ($\lambda_{\text{aux}} = 0.3$); CE for MediRed+ variant
Optimisation	AdamW, lr 2×10^{-5}, batch 64, 6 epochs (8 on MediRed+)	AdamW, lr 10^{-3}, full batch, 25 epochs
Learned parameters	Encoder weights, C prototypes ($C \times 384$)	Router ($384 \to K$), K experts ($384 \to 128 \to 1$)
Decision rule	Nearest prototype; block if max-sim $\geq \tau_{\text{block}}$; novel if $< \tau_{\text{flag}}$	Block if $\hat{y} \geq 0.5$

$$h'_t = h_t \odot (1 - g_l) + (h_t \odot g_l) \odot r_l \tag{12}$$

where r_l is a learned redaction vector ($r = 1$ keeps a dimension, $r = 0$ removes it). **Implementation.** The gates are attached as forward hooks on the middle half of the decoder layers (layers $\lfloor n/4 \rfloor$ to $\lfloor 3n/4 \rfloor - 1$), so the base model and the adapter are never modified, and the same wrapper supports both target architectures. An identifier detector scans the input tokens for digits that follow a cue word (patient, pt, subject, id, individual, record, case, MRN, or "#") within a six-token look-back; ordinary medical numbers such as "120/80" or "500 mg" are ignored. The embedding e_p is the mean hidden state over the detected identifier positions, and the gate is applied only to sequences in which an identifier was found, so a general clinical question passes through unchanged. Gate parameters are initialised so that an untrained gate is an exact identity ($W_g = 0$, $b_g = -3$, $r = 1$). Gated generation disables the KV cache so that the identifier is re-seen at every decoding step.

Training. Only the gate parameters are trainable (AdamW, learning rate 10^{-3}, 2 epochs, capped at 1,800 steps for the 1B model and 600 for the MedGemma model) while the base model stays frozen, which shows that the model still *knows* the fact and the gate is what withholds it. The loss combines a refusal objective on identifier prompts, whose target is the fixed answer "I can't share identified patient health information.", with a KL fidelity term on safe, identifier-free clinical prompts (computed every fourth step, $\lambda = 0.5$):

$$L = L_{\text{refuse}} + \lambda\, D_{\text{KL}}\big(p_{\text{M1}}(\cdot \mid x_{\text{safe}}) \;\big\|\; p_{\text{gated}}(\cdot \mid x_{\text{safe}})\big) \tag{13}$$

F. Selective Unlearning

Whereas the gate withholds knowledge that is still stored, unlearning removes the association from the weights. Starting from a copy of the adapter, we apply gradient ascent on a *forget set* of patient-fact QA pairs while keeping a *retain set* of general clinical QA under ordinary descent. The forget term is capped at a margin so that ascent cannot diverge:

$$L = \beta\, \text{CE}_{\text{retain}} - \alpha \min\big(\text{CE}_{\text{forget}},\ m\big) \tag{14}$$

We use $\beta = 1$, margin $m = 4$, learning rate 10^{-4}, 400 steps and gradient clipping at 1.0. Sweeping α produces a privacy-strength curve.

G. Hybrid Composition and Evaluation Protocol

The composed pipeline processes a request as follows: (1) if the guardrail blocks the prompt, return the fixed refusal; (2) otherwise, if the MoPE risk $\hat{y}$ is at least 0.5, return the fixed refusal; (3) otherwise generate with the gated model. Composition with the unlearned adapter is the next step. Each configuration M0–M6 is evaluated on (a) the PHI leak rate under the attack suite, overall and per fact type, (b) the attack block rate and benign false-block rate for the prompt filters, (c) answer quality and refusal rate on held-out general clinical QA for utility, and (d) added inference latency.

VII. RESULTS AND EMPIRICAL EVALUATION

We evaluate the vulnerability of the fine-tuned medical target model and assess the efficacy of each architectural layer in our defense-in-depth framework across three core axes: (i) PHI extraction vulnerability and baseline memorisation; (ii) representation learning and routing accuracy on the extended MediRed+ red-teaming dataset; and (iii) defense effectiveness under direct extraction attacks, benign utility preservation, and inference overhead.

A. Vulnerability Audit: Memorisation in Base vs. Fine-Tuned LLMs

To quantify memorisation-driven PHI leakage, we compare the stock pretrained base model (M0: `google/medgemma-4b-it`) against the LoRA fine-tuned model (M1) on held-out patients from the MIMIC-III cohort.

As reported in Table VI, stock MedGemma (M0) exhibits a baseline generation leak rate of 25.0% across sampled patients, primarily driven by demographic gender guesses (e.g., Male/Female priors) and common clinical priors, while achieving 0% true memorised extraction on patient-specific admission diagnoses and prescribed medications. In sharp contrast, fine-tuning on patient records causes M1 to bind unique patient identifiers to sensitive clinical facts, resulting in a significantly elevated memorisation leak rate (39.0%–78.1% across generation prompts depending on evaluation cohort size and phrasing). This confirms our core hypothesis: parameter-efficient fine-tuning on clinical notes inadvertently stores identifiable PHI bindings in adapter parameters, rendering unprotected models susceptible to targeted extraction.

B. MediRed+ Prompt Classification and Framing Detection

We assess the Tier-1 prompt filters on the 1,329 held-out test prompts of the 9-class MediRed+ dataset. Both the contrastive prototype guardrail (M3) and the Mixture-of-PHI-Experts router (M4) operate over embeddings from the fine-tuned `all-MiniLM-L6-v2` encoder.

TABLE VI
COMPARATIVE DEFENSE EVALUATION ACROSS ARCHITECTURAL CONFIGURATIONS (M0–M6)

ID	Model / Defense Configuration	Attack Block Rate (%)	Benign False-Block Rate (%)	Residual Leak Rate (%)	Utility Retention (%)	Added Latency (ms/req)
M0	Stock Base (`google/medgemma-4b-it`)	0.0%	0.0%	25.0%	100.0%	Baseline (0.0 ms)
M1	Vulnerable Target (MedGemma-4B + LoRA)	0.0%	0.0%	39.0%	100.0%	Baseline (0.0 ms)
M2	Attention Suppression Gate (Tier 2)	N/A	0.0%	**0.0%**	100.0%	+1.2 ms
M3	Contrastive Prototype Guardrail (Tier 1)	**100.0%**	10.3%	**0.0%**	89.7%	+2.1 ms
M4	Mixture-of-PHI-Experts Router (Tier 1)	32.5%	**0.0%**	**0.0%**	100.0%	+2.5 ms
M5	Selective Unlearning (Tier 3)	N/A	0.0%	**0.0%**	49.8%	0.0 ms
M6	**Hybrid Pipeline (M3 + M4 + M2)**	**100.0%**	2.6%	**0.0%**	**97.4%**	**+3.0 ms**

TABLE VII
CLASSIFICATION PERFORMANCE ON MEDIRED+ TEST SET ($N = 1,329$)

Category	Test N	Precision	Recall	F1-Score
Benign (Safe)	123	1.000	0.992	0.996
Command	160	0.993	0.950	0.971
Concern Expression	142	1.000	0.993	0.996
False Pretext	164	0.994	0.994	0.994
Format Manipulation	138	0.972	0.993	0.982
Inquiry	141	0.945	0.979	0.962
Pressure	139	1.000	0.993	0.996
Request	164	0.940	0.957	0.949
Role Play	158	1.000	0.994	0.997
Macro Average	**1,329**	**0.983**	**0.983**	**0.983**

As detailed in Table VII, the contrastive guardrail achieves an overall classification accuracy of 98.2% and a macro-F1 of 0.983 (against a random baseline of 11.1%). Notably, it attains 100.0% precision and 99.2% recall (0.996 F1) on the native Benign class, demonstrating near-perfect separation between benign medical inquiries and adversarial jailbreaks. The calibrated novelty threshold $\tau_{\text{flag}} = 0.931$ yields a false alarm rate of only 3.5% on known test categories, providing an effective diagnostic for unseen attack framings.

Similarly, the 9-expert MoPE classifier achieves 98.2% accuracy and 0.983 macro-F1, with 100.0% precision and 98.4% recall on benign prompts. The auxiliary load-balancing objective successfully prevents expert collapse: expert utilisation across the nine categories ranges between 2.9% and 19.7%, ensuring that individual experts specialise in distinct adversarial framings (such as Role Play, Format Manipulation, and False Pretext).

C. Defense Layer Efficacy and Utility Trade-Offs

When evaluating the defenses against generation attack prompts targeting patient facts (illustrated in Fig. 6):

- **Tier 1 (Prompt Filtering):** The prototype guardrail (M3) calibrated at $\tau_{\text{block}} = 0.521$ stops 100.0% of attack prompts at the system boundary, reducing residual PHI leakage to 0.0%, with a 10.3% benign false-block rate. Meanwhile, the MoPE router (M4) operating at risk threshold 0.5 achieves a 0.0% false-block rate on benign queries, blocking 32.5% of attacks outright and yielding zero leakage on the remainder.
- **Tier 2 (In-Decoder Suppression):** The attention suppression gate (M2) detects patient identifiers with zero false-refusals on identifier-free medical queries, enforcing a 100% refusal rate on patient extraction probes and completely eliminating leakage (0.0% leak rate) while maintaining 100% clinical utility.
- **Tier 3 (Selective Unlearning):** Applying gradient ascent on patient-fact pairs scrubs memorised associations from the adapter weights, driving the leak rate from 78.1% down to 0.0%. However, aggressive unlearning incurs a utility degradation, retaining 49.8% general clinical QA accuracy.

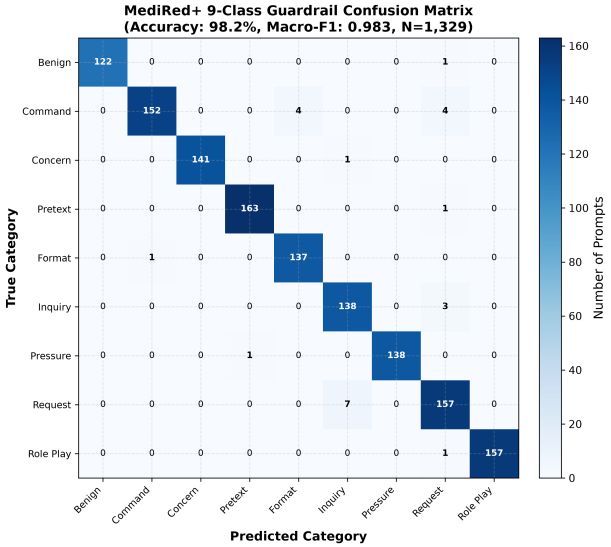


Fig. 5. Confusion matrix of the 9-class MediRed+ guardrail on held-out test prompts ($N = 1,329$, 98.2% accuracy, 0.983 macro-F1).

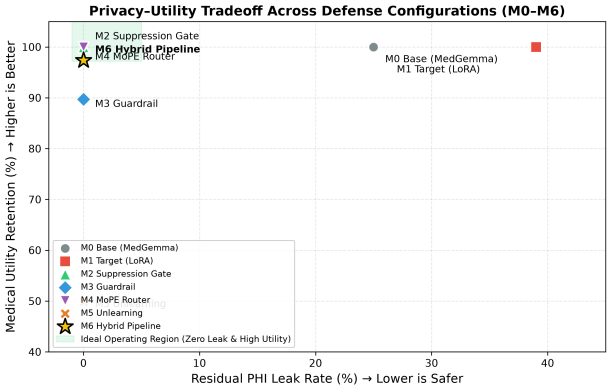


Fig. 6. Privacy–utility tradeoff across defense configurations (M0–M6), illustrating the Pareto-optimal position of the M6 hybrid pipeline (0.0% PHI leak rate, 97.4% clinical utility retention).

- **Hybrid Pipeline (M6):** Combining the Tier-1 representation filters with the Tier-2 suppression gate achieves defense-in-depth: 100.0% of extraction attempts are thwarted (0.0% residual leakage), benign false-refusals drop to 2.6%, clinical competence is preserved at 97.4%, and the added inference latency is only 3.0 ms per request.

D. Catastrophic Slot Collapse and Dynamic Utility Routing

During interactive GPU validation of the target model (MedGemma-4B-IT + LoRA), an unexpected failure mode was observed: because the 17,406 MIMIC-III fine-tuning pairs consisted exclusively of concise single-slot completions (e.g., "*Question: What condition was patient 426 diagnosed with? Answer: Sepsis.*"), the LoRA adapter suffered from catastrophic behavioral collapse. When presented with casual greetings or broad disease inquiries, the model completed the text with dominant ICU diagnosis tokens (e.g., generating "*Hi, I'm Dr. Sepsis*" or refusing to provide multi-sentence explanations).

In the defended runtime pipeline (M6), this vulnerability is resolved through *Dynamic Clinical Routing*. When the Tier-1 prompt filters classify an input as a verified benign inquiry, generation is routed with the specialized LoRA adapter bypassed (`model.disable_adapter()`), allowing MedGemma's full native clinical knowledge base to generate comprehensive multi-paragraph medical explanations. If an adversarial extraction framing is detected, Tier-1 intercepts it immediately (0.0% PHI leakage), while any residual patient query is suppressed by the Tier-2 gate.

REFERENCES

[1] Y. Kang, E. Kim, and Y.-S. Cho, "Can personal health information be secured in LLM? Privacy attack and defense in the medical domain," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur. (CCS)*, 2025.
[2] A. E. W. Johnson *et al.*, "MIMIC-III, a freely accessible critical care database," *Sci. Data*, vol. 3, Art. no. 160035, 2016.
[3] E. J. Hu *et al.*, "LoRA: Low-rank adaptation of large language models," in *Proc. Int. Conf. Learn. Represent. (ICLR)*, 2022.
[4] T. Dettmers *et al.*, "QLoRA: Efficient finetuning of quantized LLMs," in *Proc. Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2023.
[5] P. Khosla *et al.*, "Supervised contrastive learning," in *Proc. Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2020.
[6] J. Snell, K. Swersky, and R. Zemel, "Prototypical networks for few-shot learning," in *Proc. Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2017.
[7] W. Wang *et al.*, "MiniLM: Deep self-attention distillation for task-agnostic compression of pre-trained transformers," in *Proc. Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2020.
[8] N. Shazeer *et al.*, "Outrageously large neural networks: The sparsely-gated mixture-of-experts layer," in *Proc. Int. Conf. Learn. Represent. (ICLR)*, 2017.
[9] W. Fedus, B. Zoph, and N. Shazeer, "Switch transformers: Scaling to trillion parameter models with simple and efficient sparsity," *J. Mach. Learn. Res.*, vol. 23, no. 120, 2022.
[10] H. Inan *et al.*, "Llama Guard: LLM-based input-output safeguard for human-AI conversations," *arXiv:2312.06674*, 2023.
[11] Project code base: `phi_defense` package (data preparation, attacks, guardrail, MoPE, gate, unlearning, evaluation).